Appraisal and Evaluation of the Attention Based View Theory

Written Report

Ben Victor Webb
WEB19693825

Assessment Case Study for
Information Systems Security

19693825@students.lincoln.ac.uk
School of Computer Science
University of Lincoln
United Kingdom

January 6th 2025

TABLE OF CONTENTS

I Introduction 2

II Case Study Paper - Appraisal of Theoretical Model and Hypothesis 2

II-A Description of the Theoretical Model 2

II-B Merits and Strengths of the Model 2

II-C Limitations and Critiques of the Model 3

III New Model 3

III-A Introduction 3

III-B Theoretical Foundation of the Model 3

III-C Key Components of the Top-Down Model 3

III-D Importance of Top Management Buy-In 4

III-E Application and Real-Life Cases 4

IV Conclusion 5

References 5

I. Introduction

Cybersecurity breaches represent a critical and growing challenge for organisations worldwide, requiring strategic responses that extend beyond technical solutions. In this context, the case study by Shaikh and Siponen (2023) introduces the Attention-Based View (ABV) model, emphasising the role of Top Management Team (TMT) attention in shaping organisational responses to cybersecurity breaches. The study highlights a casual pathway, which subsequently influences the likelihood of conducting Information Security Risk Assessments (ISRAs). This approach underscores the strategic value of leadership in navigating cybersecurity challenges, bridging theoretical insights from organisational behaviour with practical cybersecurity concerns.

This essay critically appraises the ABV model, evaluating its merits, strengths, and limitations. While the model offers valuable insights into the influence of leadership attention on breach response, it also reveals gaps, such as the exclusion of external regulatory pressures and the oversimplification of organisational decision-making pathways. Building on this critique, the essay proposes a new ”top down” model for ISRA that integrates strategic leadership, organisational alignment, and external regulatory drivers. By emphasising proactive management and systemic adaptability, the proposed model seeks to address the identified shortcomings and provide a comprehensive framework for cybersecurity risk assessment.

II. Case Study Paper - Appraisal of Theoretical Model and Hypothesis

A. Description of the Theoretical Model

The case study article [16] presents the Attention-Based View model as a solution to cybersecurity breaches which posits that organisational actions are shaped by where decision-makers, such as the Top Management Team, focus their attention.

Applying this to cybersecurity, the model identifies a casual pathway, hypothesising that the magnitude of breach costs directs the TMT’s attention towards cybersecurity, thereby influencing subsequent actions like conducting Information Security Risk Assessments (ISRAs).

Finally, their method’s results are also empirically tested to test the model’s pathway: the relationship between cybersecurity breach costs and increased TMT attention to cybersecurity, which results in the likelihood of conducting ISRAs. The hypothesis tests these relationships empirically, using data obtained from organizations that have already experienced cybersecurity breaches.

B. Merits and Strengths of the Model

Both Shaikh and Siponen introduce a novel application of the Attention-Based View model. This study applies the ABV model to the domain of cybersecurity, which it is traditionally used in organisational decision-making contexts [10][12][13]. In doing so, the authors bridge the gap between theoretical frameworks in organisational behaviour and practical cybersecurity challenges. Furthermore, the model emphasises how the attention of the top management team (rather than just technical staff) plays a critical role in shaping cybersecurity strategies. This perspective highlights the importance of leadership in driving effective responses to cybersecurity issues.

Further merits of the model are through their managerial implications. Trying to emphasise managerial strategic value, the study underscores the importance of aligning cybersecurity responses with organisational priorities and leadership focus, demonstrating that effective cybersecurity management is not just a technical challenge but a strategic one. This article provides actionable insights for firms to consider how a management’s focus can directly influence the adoption of risk assessments which can be crucial for mitigating future breaches. Lastly, the managerial implications can encourage proactive leadership. By showing that breach costs can drive attention to cybersecurity, the model implicity encourages organisations to proactively engage top management in cybersecurity planning, rather than waiting for a breach to occur.

The article’s focus on Top Management Team attention highlights a leadership’s role in Cybersecurity Research. The model explicitly positions TMT as a mediator, emphasising that leadership focus is a critical determinant of whether organisations conduct ISRAs after a breach. This aligns cybersecurity responses with organisational governance, a valuable contribution, as many organisations struggle to integrate cybersecurity into top-level decision-making [4][11].

Another strength of the model is its holistic perspective on breach responses. Looking beyond immediate fixes, whilst other studies focus on the technical or operational responses to breaches (e.g., patching vulnerabilities [1] or upgrading software [15]), this model looks at systemic improvements through ISRAs. This long-term perspective is essential, as it suggests that addressing cybersecurity challenges requires structural changes rather than just reactive measures. As Shaikh and Siponen highlight in their model [16], ISRAs encourage comprehensive reviews through encouraging organisations to identify vulnerabilities beyond the scope of the specific breach incident. This proactive approach can help organisations build stronger defences against future attacks.

The final strength is present through its empirical validation of the relationships presented. In its tested pathways, the study empirically validates the hypothesised relationships, particularly the mediating role of the TMT's attention. This strengthens the credibility of the model by showing that the relationship between the breach costs, TMT attention, and ISRAs are not merely theoretical but observable in practice. The paper has also proven to be practically relevant, by focusing on real-world organisational responses to breaches, the model aligns closely with the challenges faced by practitioners, enhancing its applicability.

C. Limitations and Critiques of the Model

One of the limitations of the proposed model is its simplistic casual pathway. The model assumes a linear relationship between breach costs and TMT attention, but organisational decision-making might be influenced by additional factors such as organisational culture [9][19], prior investment in cybersecurity [17], or external pressure from stakeholders [18].

A further significant limitation of the model proposed is its neglect of external influences, and how external regulatory requirements or industry norms are not incorporated but could significantly affect ISRA's adoption. Theoretical models that examine organisational behaviour often face the challenge of accounting for external factors that significantly shape decision-making. In the context of cybersecurity, external regulatory requirements, industry norms, and stakeholder expectations are critical drivers of behaviour but are absent in Shaikh and Siponen's model. With the role of regulatory requirements, governments and regulatory bodies impose cybersecurity standards that organisations must comply with, such as the General Data Protection Regulation (GDPR) in Europe, or the Health Insurance Portability and Accountability Act (HIPAA) in the US. These regulations often mandate specific actions, such as risk assessments, irrespective of whether top management team attention is high or breach costs are significant [7][21]. Organisations that fail to comply face legal penalties, reputational damage, or loss of business opportunities, creating a strong external driver for conducting ISRAs.

Another critique of the model is its potential overemphasis on breach costs. While breach costs are an important driver for the organisational decision-making, other aspects such as reputational damage or employee trust could also direct TMT's attention towards cybersecurity.

Finally, there appears to be insufficient contextualization of ISRAs, where the study presented by Shaikh and Siponen does not deeply explore the nature or effectiveness of the ISRAs themselves, which could vary widely between organisations.

III. New Model

A. Introduction

In response to Shaikh and Siponen's theory model, I propose a new "top down" model for Information Security Risk Assessment (ISRA) that emphasises the integration of Top Management Team (TMT) attention and organisational governance into the risk assessment process. This model is built upon the foundational theories of strategic management and behavioural decision-making, which highlights the pivotal role of leadership in shaping organisational priorities and driving effective risk management. By addressing the limitations of the aforementioned linear casual pathways and incorporating external influences, this model presents a holistic approach to ISRA that is both proactive and strategic.

B. Theoretical Foundation of the Model

The proposed model is influenced by the following theoretical perspectives. The Upper Echelons Theory conducted by Donald C. Hambrick and Phyllis A. Mason [8] posits that organisational outcomes are a reflection of the values, experiences, and cognition of top executives. Applying this theory to ISRA underscores the necessity of top management buy-in to drive security initiatives.

Furthermore, the theory presented in Richard M. Cyert and James G. March's book "*A behavioral theory of the firm*" [3] emphasises the role of decision-making processes within organisations, particularly under conditions of uncertainty. It supports the idea that risk assessments should align with organisational goals and leadership priorities.

Finally, Paul J. DiMaggio and Walter W. Powell's paper on "*The Iron Cage Revisited: Institutional Isomorphism and Collective Rationality in Organizational Fields*" [5] discusses how organisations within the same field become increasingly similar through processes of coercive, mimetic, and normative isomorphism. This became a pivotal work for understanding how institutional pressures shape organisational behaviour, which is where they presented the Institutional Theory. Which highlights how external pressures, such as regulatory compliance and industry norms, shape organisational practises. Integrating this perspective into the new "top down" model ensures the model accounts for the influence of external stakeholders.

C. Key Components of the Top-Down Model

The model consists of three interconnected layers. The first layer is strategic alignment, where to encourage leadership engagement, top management must actively participate in cybersecurity strategy formulation and risk assessment discussions. To further enforce this strategic alignment, there must be a clear vision and objectives put in place, so that the ISRA must align with the organisation's broader strategic goals to ensure its prioritisation.

The second layer enforces a comprehensive ISRA framework. To ensure an integrated risk management, risk assessments should incorporate technical, operational, and strategic risks, ensuring a balanced view of threats and vulnerabilities. And to reinforce stakeholder collaboration, it is vital to engage the internal stakeholders (such as IT and HR departments) as well as external stakeholders (such as regulators and customers) to capture diverse perspectives.

The final connected layer provides the potential for future-proofing and system safety with continuous monitoring and adaptations. With implementing dynamic risk assessments, the model emphasises iterative and adaptive risk assessments to respond to evolving threat landscapes. Additionally, with a definition of continuous reports on clear performance metrics, this allows an evaluation of the effectiveness of ISRA processes and their alignment with organisational objectives.

D. Importance of Top Management Buy-In

Top management is the pivotal pillar for strategic leadership within a company, and their involvement signals organisational commitment to cybersecurity, cultivating a security-first culture. George Westerman, Didier Bonnet and Andrew McAfee's book "*Leading Digital: Turning Technology into Business Transformation*" explores how large companies in traditional industries are using digital technologies to gain strategic advantages [20]. Studies such as this have shown that leadership buy-in significantly enhances the success of digital transformation initiatives, including cybersecurity programs.

Top management also direct a company's resource allocation, where leaders control budgetary and human resources. Their support ensures adequate allocation for implementing robust risk assessments and mitigating identified vulnerabilities.

Finally, the importance of top management buy-in is to ensure proactive risk mitigation. Leadership commitment encourages a shift from reactive to proactive security measures such as Google's Project Zero initiative, that demonstrates how strategic foresight can lead to industry-leading vulnerability management practices [14].

E. Application and Real-Life Cases

In 2017, Equifax - one of the largest US consumer credit reporting agencies - announced its systems had been breached and 148 million Americans had their sensitive personal data compromised, including "*names, home addresses, phone numbers, dates of birth, social security numbers, and driver's license numbers. The credit card numbers of approximately 209,000 consumers were also breached*"[6]. The vulnerability that caused the breach was "*vulnerability Apache Struts CVE-201705638*". On March 7th 2017, the Apache Software Foundation announced the vulnerability and released a patch. On March 9th 2017, an internal email sent to Equifax administrators informed them to apply the patch, to which the information security department ran scans of their systems to identify the vulnerability on March 15th but nothing was found. Having left the vulnerability unpatched until July 29th 2017, Equifax's information security department discovered "*suspicious network traffic*", which resulted in Equifax discovering the enormity of their data breach on July 30th 2017. From this breach, Equifax failed to patch a known vulnerability, resulting in an immense data breach. Whereas a "top down" approach could have ensured that leadership prioritised patch management and conducted thorough risk assessments, potentially averting the breach.

Also in 2017, a Danish shipping and logistics company called Maersk was the victim of a devastating NotPetya attack. In June 2017, Maersk employees were receiving messages advising them that their file systems were being repaired, which juxtaposed other employees messages, which stated that their important files had been encrypted and demanded a ransom of $300 in bitcoin for the encryption key. This had a knock-on effect to cause mass company panic in Maersk headquarters, where "*entry systems and phone networks had been rendered useless by the apparent malware spreading rapidly throughout the company's network and beyond. By the end of the day, their network had been so deeply corrupted that the company simply shut down*"[2]. In response to this attack which was an "*expensive and significant wake-up call*", it pointed to the necessity for "*education and diligence in promoting and practising cyber hygiene and instituting robust cyber defences*". The severity of this attack encouraged a strong leadership to enable rapid recovery and spurred investments in advanced cybersecurity measures, which aligns with our model's emphasis on proactive leadership.

Finally, the implementation of the General Data Protection Regulation (GDPR) law in 2018 that governs the collection, processing, and storage of personal data, introduced comprehensive data protection laws across the European Union. Its enforcement reshaped organisational approaches to information security, making privacy and data protection a core focus for businesses. With its implementation, organisations across Europe conducted extensive ISRAs post-GDPR to align with compliance requirements, driven largely by leadership's awareness of legal and reputational risks.

IV. Conclusion

The proposed "top down" model for ISRA addresses key gaps identified in Shaikh and Siponen's work by integrating top management's strategic focus, organisational alignment, and external regulatory pressures into a cohesive framework. By emphasising leadership's role in fostering a proactive, comprehensive, and adaptive approach to cybersecurity, this model offers a robust pathway for organisations to enhance their resilience against emerging threats while aligning with broader strategic goals. Future research could explore the model's practical implementation across different industries, further validating its application in diverse organisational contexts.

References

[1] Caiazzo, P. (2020) *Why Patch Management Is Important For Cyber Security*. Arizona, Tennessee: Avertium. Available from https://www.avertium.com/blog/why-patch-management-is-important-for-cyber-security [accessed 03 January 2025].

[2] Capano, D.E. (2021) *Throwback Attack: How NotPetya Ransomware Took Down Maersk*. Available from https://www.industrialcybersecuritypulse.com/threats-vulnerabilities/throwback-attack-how-notpetya-accidentally-took-down-global-shipping-giant-maersk/ [accessed 05 January 2025].

[3] Cyert, R.M. and March, J.G. (1963) *A behavioral theory of the firm*. New Jersey: Englewood Cliffs. Available from https://archive.org/details/behavioraltheory0000cyer [accessed 05 January 2025].

[4] Delinea News (2023) *Global Research from Delinea Reveals That 61% of IT Security Decision Makers Think Leadership Overlooks the Role of Cybersecurity in Business Success*. San Francicso. Available from https://delinea.com/news/global-research-leadership-overlooks-cybersecurity [accessed 03 January 2025].

[5] DiMaggio, P.J. and Powell, W.W. (1983) The iron cage revisited: Institutional isomorphism and collective rationality in organizational fields. *American Sociological Review*, 48(2), 147-160

[6] Electronic Privacy Information Center (2018) *Equifax Data Breach*. Washington: Electronic Privacy Information Center. Available from https://archive.epic.org/privacy/data-breach/equifax/ [accessed 05 January 2025].

[7] Flores, D.A. and Perugachi, R. (2023) A GDPR-compliant Risk Management Approach based on Threat Modelling and ISO 27005. Available from https://arxiv.org/abs/2306.04783# [accessed 03 January 2025].

[8] Hambrick, D.C. and Mason, P.A. (1984) Upper Echelons: The Organization as a Reflection of Its Top Managers. *The Academy of Management Review*, 9(2), 193-206. Available from https://doi.org/10.2307/258434 [accessed 05 January 2025].

[9] Hu, Q., Dinev, T., Hart, P. and Cooke, D. (2012) Managing Employee Compliance with Information Security Policies: The Critical Role of Top Management and Organizational Culture. *Decision Sciences*, 43(4) 615-660. Available from https://onlinelibrary.wiley.com/doi/abs/10.1111/j.1540-5915.2012.00361.x [accessed 03 January 2025].

[10] Joseph, J. and Wilson, A.J. (2017) The growth of the firm: An attention-based view. *Strategic Management Journal*, 39(6), 1779-1800. Available from https://onlinelibrary.wiley.com/doi/abs/10.1002/smj.2715 [accessed 03 January 2025].

[11] Kaplan, J., Sharma, S. and Weinberg, A. (2011) Meeting the cybersecurity challenge. Available from https://www.mckinsey.com/capabilities/mckinsey-digital/our-insights/meeting-the-cybersecurity-challenge [accessed 03 January 2025].

[12] Ocasio, W. (1998) Towards An Attention-Based View Of The Firm. *Strategic Management Journal*, 18(S1), 187-206. Available from https://onlinelibrary.wiley.com/doi/abs/10.1002/(SICI)1097-0266(199707)18:1+%3C187::AID-SMJ936%3E3.0.CO;2-K [accessed 03 January 2025].

[13] Ocasio, W., Laamanen, T. and Vaara, E. (2017) Communication and attention dynamics: An attention-based view of strategic change. *Strategic Management Journal*, 39(1), 155-167. Available from https://onlinelibrary.wiley.com/doi/full/10.1002/smj.2702 [accessed 03 January 2025].

[14] Project Zero (2014) *About Project Zero*. Available from https://googleprojectzero.blogspot.com/p/about-project-zero.html [accessed 05 January 2025].

[15] Rundle, J. and Lin, B. (2024) Fast and Automated: Global Tech Outage Shows Hazards of Cloud Software Updates. *WSJ PRO CYBERSECURITY*. Available from https://www.wsj.com/articles/global-tech-outage-shows-perils-of-speed-versus-safety-in-it-updates-01eedab4 [accessed 03 January 2025].

[16] Shaikh, F.A. and Siponen, M. (2023) Information security risk assessments following cybersecurity breaches: The mediating role of top management attention to cybersecurity. *Computers and Security*, 124(C). Available from https://dl.acm.org/doi/10.1016/j.cose.2022.102974 [accessed 03 January 2025].

[17] Stupp, C. (2024) Cyber Spending Rises Modestly While Hacking Threats Evolve *WSJ PRO CYBERSECURITY*. Available from https://www.wsj.com/articles/cyber-spending-rises-modestly-while-hacking-threats-evolve-8c0e0c3c [accessed 03 January 2025].

[18] Wall Street Journal Video (2024) *New York State's Cybersecurity Strategy*. Available from https://www.wsj.com/video/events/new-york-state-cybersecurity-strategy/1EC1C050-87CA-4A53-99CB-3DE034B4A840 [accessed 03 January 2025].

[19] Willie, M.M. (2023) The Role of Organizational Culture in Cybersecurity: Building a Security-First Culture. *Journal of Research, Innovation and Technologies*, 2(4) 179-198. Available from https://doi.org/10.57017/jorit.v2.2(4).05 [accessed 03 January 2025].

[20] Westerman, G., Bonnet, D. and McAfee, A. (2014) *Leading Digital: Turning Technology into Business Transformation*. Harvard Business Press.

[21] Zarrabi, F., Wagner, I. and Boiten, E. (2023) Changes in Conducting Data Protection Risk Assessment and After GDPR implementation. Available from https://arxiv.org/abs/2304.11876 [accessed 03 January 2025].